पृ thak

airtel Payments Bank

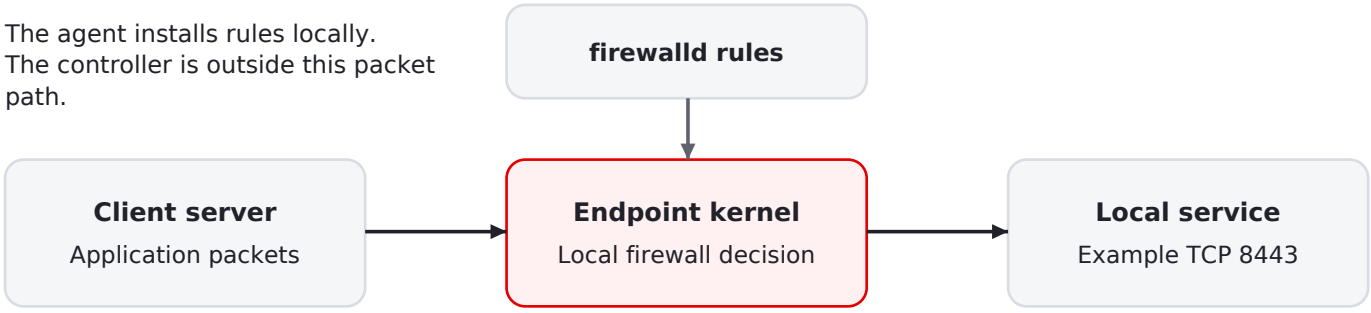
COMPONENTS COMMUNICATION OPERATING PROCESSES

Prṛthak Architecture and Operations Guide

How the controller and Linux agent work together

One reference for infrastructure, security and application teams. It explains the component roles, network paths, identity, installation, service discovery, policy lifecycle, temporary learning, HA and recovery.

The agent installs rules locally. The controller is outside this packet path.



Prepared for Pratik. Version 0.6.0, unpublished development edition, 31 October 2026. Current controller capacity is measured with virtual identities; DC deployment and native RHEL/Ubuntu acceptance remain deferred. The 20-server pilot has not started.

Copyright 2026 Airtel Payments Bank Limited. All rights reserved. Product branding follows the existing project assets. This working guide does not represent production approval.

READER MAP

How to use this guide

The model is central intent with local enforcement. Administrators manage source and service policy through the API-backed dashboard. Each endpoint pulls signed intent, checks its authority and applies supported firewalld rules locally. The Linux kernel handles application packets.

Read pages 3 to 9 before provisioning; pages 10 to 18 before onboarding and policy design; pages 19 to 25 before enabling writes or recovery. Pages 26 to 31 cover exceptions, capacity, acceptance and reference commands.

Implemented stack: Go endpoint; Python and Gunicorn controller; JavaScript/HTML/CSS dashboard; PostgreSQL 16 with Patroni/etcd and HAProxy. Local setup uses SQLite.

Chapter map

Read this topic	Page
System and component architecture	3
Communication and separate identities	5
HA topology and VM prerequisites	7
Controller installation and access	9
Agent CPU RAM and packages	10
Endpoint installation and enrollment	12
Runtime discovery and metadata	14
Policy design and compilation	17
Approval enforcement and rollback	19
Learning and learned policies	21
Traffic platform and recovery	23
Failure handling and capacity	26
Acceptance commands and references	28

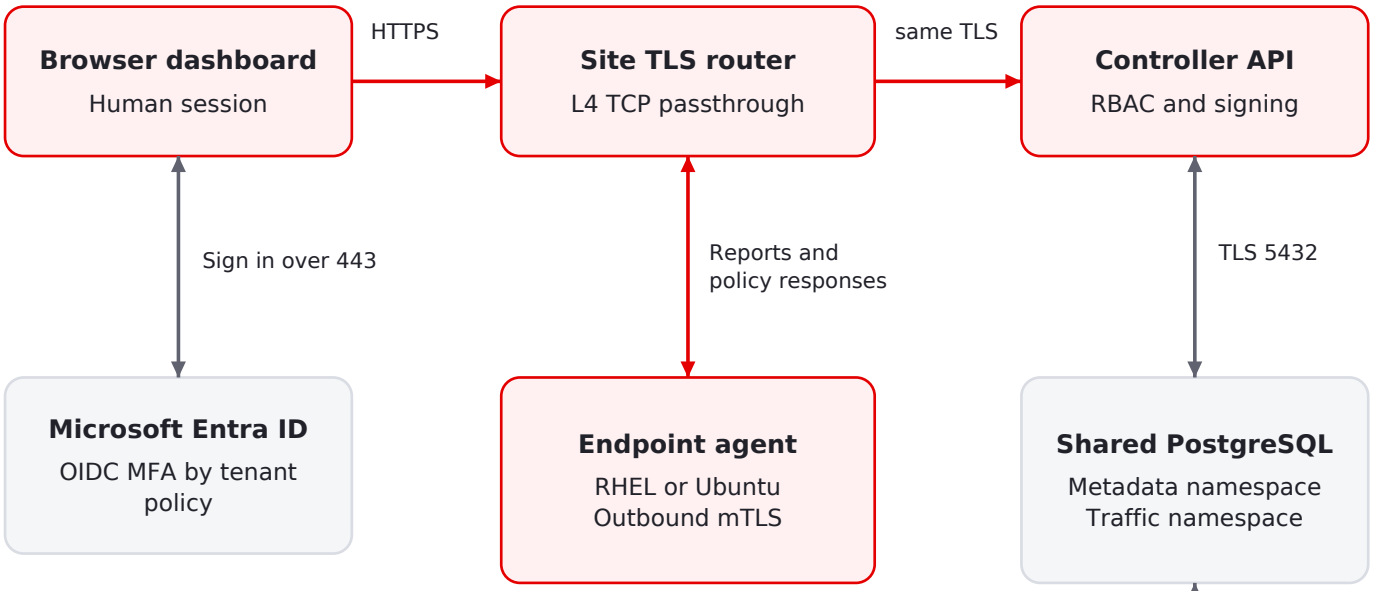
State vocabulary: intended, downloaded, approved and enforced are different states. A queued operation is not a successful host change. An observed source is not proof of a trusted application client. Example DC names and addresses in diagrams are illustrative.

Source references [1] [2]

ARCHITECTURE

System architecture

The browser and agent use the same configured HTTPS listener. The API checks the appropriate human or endpoint identity, then accesses shared metadata and traffic persistence. The controller compiles effective intent within its transactions. Background jobs evaluate absent heartbeats and process durable traffic batches.

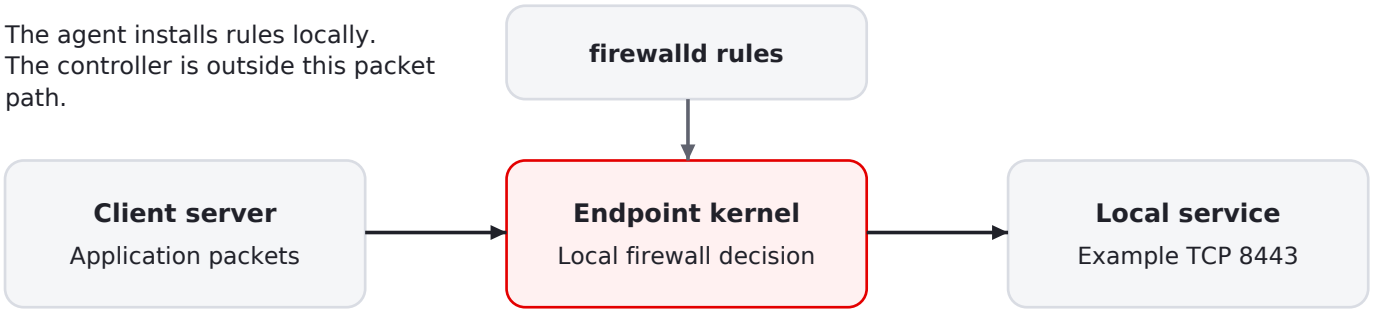


One listener

Browser and agent routes share the configured HTTPS origin. Identity and authorization checks differ by route.

Application traffic stays on the endpoint

The agent installs rules locally. The controller is outside this packet path.



Use firewalld with its nftables backend for the current adapter. Prṛthak does not proxy business traffic or add a controller hop to each application connection.

Source references [1] [3] [4]

COMPONENT RESPONSIBILITIES

What each component does

Component	Responsibility	Authority and stored state
Dashboard	Inventory, combined filters, policies, learning, alerts and platform workflows.	Calls the API; no direct database or endpoint command access.
Controller API	Human RBAC, endpoint mTLS, input validation, review and outcome endpoints.	Coordinates intent and audit. It is a high-trust fleet control component.
Policy compiler	Resolve target membership and source IPs; expand service groups.	Effective per-host bundle, digest, version and immutable history.
Signing provider	Sign complete endpoint assignments and release manifests.	Separate pinned Ed25519 public trust; optional offline provider exists.
Metadata database	Inventory, DCs, tags, policies, identities, reviews and audit.	Shared PostgreSQL in HA; SQLite is the local setup/demo baseline.
Traffic database and queue	Durable ingestion, batch deduplication, raw flows.	Separate namespace from inventory, on the configured storage backend.
Background jobs	Health, traffic processing, notifications and backup schedules.	Shared job leadership prevents duplicate coordinated work.
Runtime supervisor	Drain/restart the child controller and verify handover/recovery.	Protects local lifecycle; does not make an arbitrary shell API.
Local appliance manager	Reviewed fixed service, TLS, storage and database helper operations.	Restricted Unix socket; kernel peer UID plus private token.
Endpoint agent	Discover, report, poll, validate, learn and apply approved local changes.	Root systemd service with private durable identity/state.
firewalld and kernel	Manage local rules, then enforce packets in the kernel.	Agent-owned rules coexist with preserved unrelated configuration.

HAProxy routes verified TLS traffic. Patroni coordinates the PostgreSQL primary/standbys using etcd quorum; none of these components replaces the application approval checks.

Source references [1] [3] [5]

CONNECTIVITY

Communication and service ports

Prepare routes by initiator and purpose. Defaults below can differ from the installed public port. Discovery, heartbeat, policy and traffic uploads currently share the agent HTTPS origin; separate proposed discovery/control ports are not implemented.

Initiator to destination	Port or socket	Purpose
Browser or agent to stable origin	TCP 8787 default; 443/custom if configured	Dashboard/API or enrolled mTLS requests through L4 routing.
Site router to remote controller backend	TCP 8786	Private TLS backend and verified /readyz health routing.
Controller to approved database voters	TCP 5432	Generated multi-host DSN, verify-full TLS/SCRAM, writable-primary selection.
Optional writer router to PostgreSQL	Public router 5433; backend 5432	Available writer-routing service; generated app DSNs use voter 5432 directly.
Router to Patroni	TCP 8008	mTLS primary-health check; not a public browser API.
Patroni to etcd / etcd peer to peer	TCP 2379 / 2380	Mutually authenticated quorum coordination.
Controller management vantage to endpoint	Actual protected SSH ports	Fresh SSH-banner reachability witness, including 2022. No SSH login or remote shell.
Controller and browser to Entra	TCP 443	Tenant sign-in, discovery, token exchange and signing keys.
Controller to optional alert channel	HTTPS 443 or configured SMTP	Reviewed webhook/Slack or TLS SMTP; default SMTP port 587 STARTTLS.
Controller to local privileged manager	/run/prthak-appliance/manager.sock	Local fixed operations; no management network listener.
Agent to firewalld and journal	Local commands / D-Bus / files	No inbound agent control socket is required.

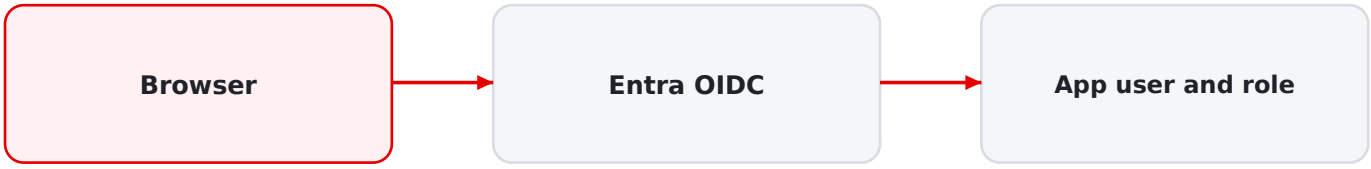
Restrict database/quorum/backend ports to approved nodes. Keep DNS and clocks reliable. The external LB must preserve endpoint client certificates with TCP/L4 passthrough; forwarded certificate or IP headers do not authenticate an agent.

Source references [4] [6] [7]

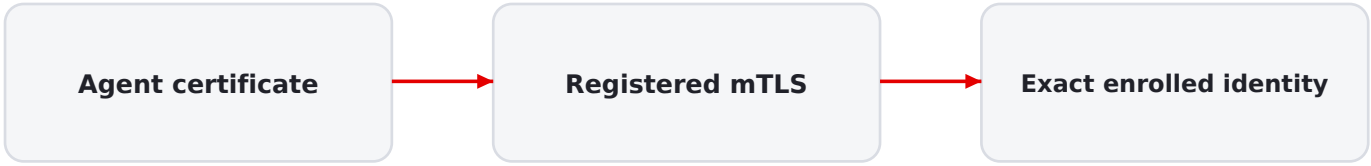
IDENTITY AND ACCESS

Three separate identity paths

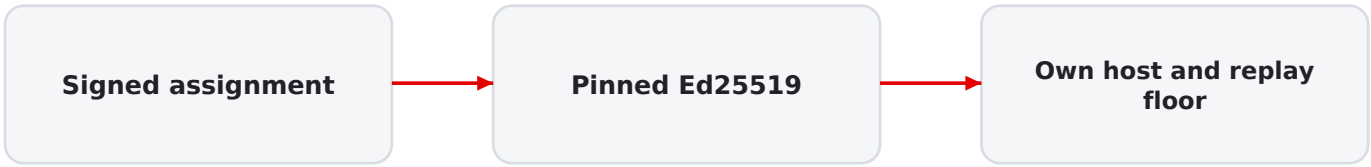
Human access



Endpoint access



Policy authenticity



Role	Operational rights	User and privileged platform rights
Read Only	View inventory, policies, traffic, alerts and evidence/export.	Cannot change configuration or create users.
Admin	Manage servers, tags/DC assignments, groups, policies, learning and enrollment.	Cannot create any user. Risky access still requires independent review.
Super Admin	Admin rights plus privileged platform operations.	Only role that manages users/roles. Critical database recovery needs two distinct Super Admins.

Entra identifies an existing person by tenant and immutable object ID. The application access table grants the role; email, directory group or claimed app-role values do not promote access. A Super Admin adds application access for an existing Entra user, not a new directory account.

Web HTTPS CA, endpoint issuing CA and assignment signing keys are separate trust decisions. Existing pins are not silently replaced during renewal or recovery.

SSO setup: record tenant ID, Web client ID, exact HTTPS /api/v1/auth/callback, a mode-0600 client-secret file and the existing bootstrap Super Admin Object ID. Configure identical values on every controller. After first sign-in, remove the bootstrap Object ID on all nodes, restart, then add a second Super Admin through Users & access.

Source references [3] [8] [9]

HIGH AVAILABILITY

Three DCs and cloud topology

This is an illustrative layout, not a statement that these sites already exist. Controllers can be active at several sites, while the shared PostgreSQL cluster has one writer. Three approved distinct-site voters carry PostgreSQL copies and etcd quorum.

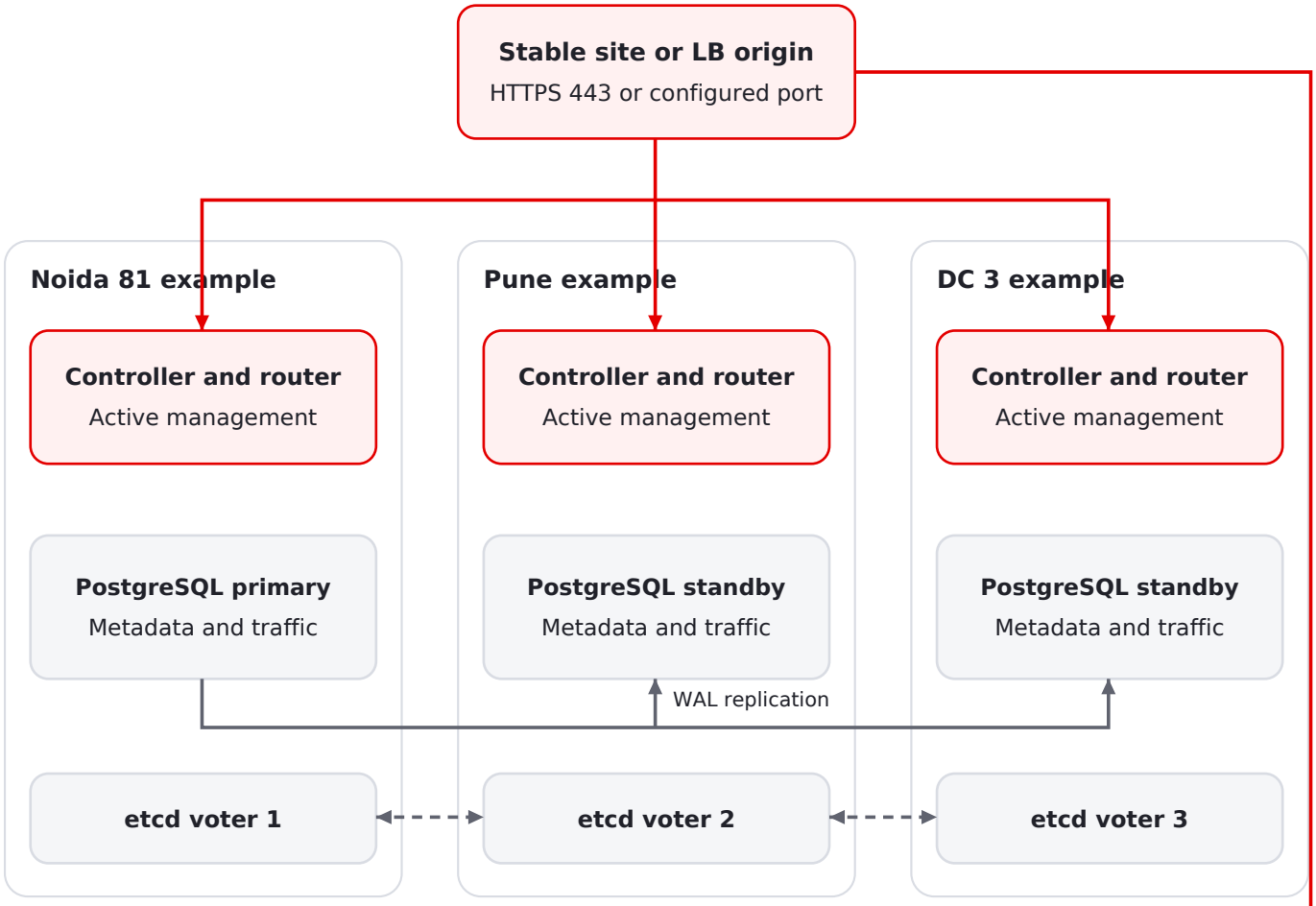
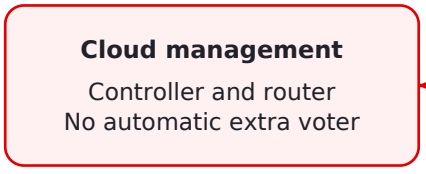


Illustration only

Create each location and join each node through the reviewed GUI workflow.



Dashed etcd edges simplify a full peer mesh. All voters must communicate over the approved peer paths.

Primary and standby roles can change only through the coordinated database/fencing path. Cloud can host extra management nodes; adding one does not create another independent writable database or a fourth voter.

Strict synchronous replication needs an eligible standby. Quorum alone does not prove writes can complete. External redundant LB/VIP/DNS, WAN partitions, native watchdog reset and physical site-loss recovery remain operator acceptance work.

Source references [4] [6] [10]

PROVISIONING

VM and host prerequisites

These are starting allocations for the current application, not certified minima. Each database voter also runs its controller/router. Budget every surviving pool for the load it will receive after failure.

VM use	vCPU	RAM	OS / Docker SSD	Separate data SSD
20-server pilot/setup	4	8 GiB	80 GiB	100 GiB
5,000 management-only	8	16 GiB	80 GiB	100 GiB
5,000 controller plus voter	8	32 GiB	80 GiB	300 GiB initially

Controller host preparation

- Genuine Linux systemd/PID1, root access, local Docker Engine and Compose v2; approved image, OS and Python package access.
- Protected root-owned system Python 3.9 or newer for the host manager. RHEL 8 default Python 3.6 is insufficient; select an approved installed interpreter with PRTHAK_INSTALL_PYTHON.
- Dedicated persistent DATA_ROOT with protected ancestors and no symlinks. Default is /var/lib/prthak. Docker image/log storage remains outside it.
- Reserve locked no-login UID/GID 10001 for the controller. The installer rejects collisions and unrelated group members.
- Approved database voters require native /dev/watchdog0 fencing. The GUI does not format/mount a disk or replace hardware fencing.

Database connection budget

```
controllers x workers x (metadata cap + traffic cap)
```

For three controllers, two workers each and pools 8/2, the pooled ceiling is 60 sessions. Add readiness, job leadership, migration, monitoring, replication and administration reserve. Storage needs grow with traffic retention, WAL, history, local backups and recovery candidates.

Source references [2] [6] [11]

CONTROLLER SETUP

Install and initialize the controller

Git is optional. Use an approved pinned checkout or the signed source installation archive. The archive includes the installer, .env.example, runtime source and browser assets; it is not a complete offline container-image installer.

Verify and configure

```
python3 /approved/tools/verify-release.py \
  --public-trust-file /approved/trust/prthak-release-public-trust.json \
  --signature prthak-controller-0.6.0.tar.gz.signature.json \
  prthak-controller-0.6.0.tar.gz
```

Verify before extraction with independently approved public trust. Extract under a protected root-owned release directory. Copy .env.example to /root/prthak-node.env with mode 0600 and edit it as data; never source untrusted environment text.

```
sudo install -d -o root -g root -m 0755 /opt/prthak/releases
sudo tar --no-same-owner --no-same-permissions \
  -xzf /protected/releases/prthak-controller-0.6.0.tar.gz \
  -C /opt/prthak/releases
cd /opt/prthak/releases/prthak-controller-0.6.0
sudo install -o root -g root -m 0600 .env.example /root/prthak-node.env
sudoedit /root/prthak-node.env
```

```
sudo ./scripts/install-controller.sh \
  --env-file /root/prthak-node.env --validate-only
sudo ./scripts/install-controller.sh \
  --env-file /root/prthak-node.env
```

Configure	Required meaning
NODE_ID SITE NODE_IP	Unique node identity, manually named site and reachable address.
CONTROLLER_ORIGIN and ports	Stable trusted HTTPS origin; initial publication defaults to 8787.
DATA_ROOT	Dedicated persistent directory; installer protects and retains identity.
Initial secrets	Private cluster/admin token or generated values; prefer an Entra secret file.
Capacity settings	Measured profile: AUTO (two PostgreSQL workers); threads 32; set SEG_DB_POOL_META_MAX=8 and SEG_DB_POOL_TRAFFIC_MAX=2; wait 5 s. Pool defaults are 16/4.

The installer enables the fixed local manager and controller/router. It prints the initial admin token file path, not the secret. Authenticated setup is distinct from shared PostgreSQL activation. Configure a confidential single-tenant Entra Web client with the stable /api/v1/auth/callback, then validate real login/MFA and provision a second independent Super Admin.

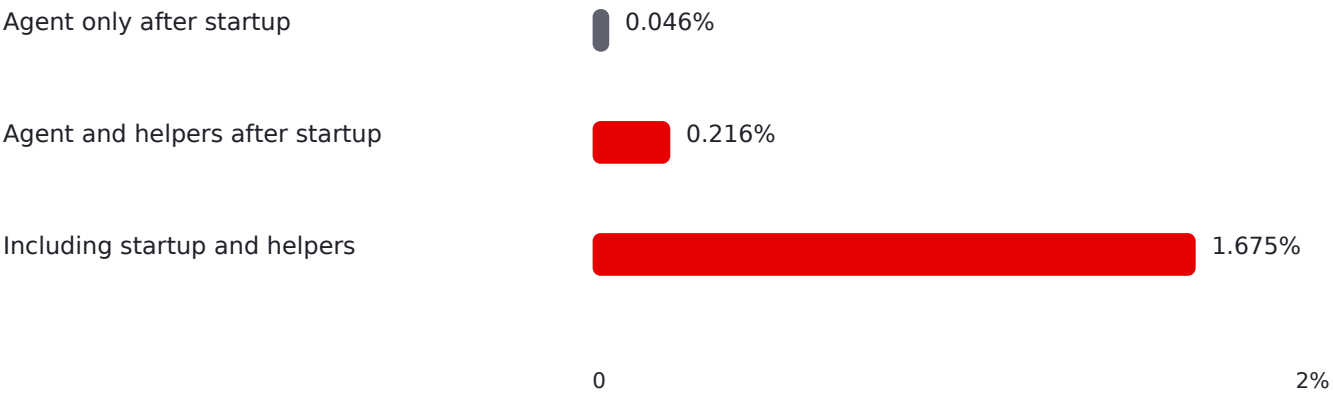
Source references [8] [11] [12]

ENDPOINT FOOTPRINT

Expected agent CPU and RAM

Use the measured passive reference below for initial expectations, then measure the intended host and workload. It was a 95-second actual Linux ARM64 agent run in an Ubuntu 26.04 container, with one loopback listener, empty policy, real discovery/enrollment/mTLS/signed polling, and 60/900-second control/discovery settings. It was not simulation.

Average CPU as percent of one core



Metric	Observed reference
Agent median / peak RSS	10.42 / 12.50 MiB
Agent plus active read helpers	56.79 MiB sampled peak RSS
CPU after startup including completed helpers	0.216% of one core over 64.893 seconds
CPU including startup and helpers	1.675% average over 94.946 seconds
Hard CPU or RAM limit	No CPUQuota MemoryHigh or MemoryMax configured

Interpretation: normal passive work is light in this small reference, but these averages are not peak caps or a native-host guarantee. The 30-second capacity polling profile was not the profile measured here. Learning, log bursts, large policies, enforcement and rollback need their own measurements.

RSS is not PSS; shared pages can be counted twice when summing children, and sampling can miss brief peaks. Firewalld/controller/D-Bus daemons, journal storage and kernel rule/source-set memory are excluded. Application packets are filtered in the kernel rather than processed one by one by the agent.

Source references [13] [14]

ENDPOINT DISTRIBUTION

Agent packages and required files

Artifact	Size	Contents and target
Linux amd64 agent archive	3,403,773 bytes	RHEL 8/9 or Ubuntu 26.04 on x86_64/amd64.
Linux ARM64 agent archive	3,064,034 bytes	RHEL 8/9 or Ubuntu 26.04 on aarch64/arm64.
Uncompressed Go executable	7.81 MiB amd64; 7.19 MiB ARM64	Static compiled agent; no Go runtime, compiler, Git or Python required to run it.
Controller source archive	618,888 bytes	Public source/installer/assets and template; no agent binary or private runtime state.

```
prthak-agent-0.6.0-linux-amd64.tar.gz
prthak-agent-0.6.0-linux-arm64.tar.gz
Each has an adjacent .tar.gz.signature.json sidecar.
```

Each agent archive has 17 regular files

The executable, config example, agent README, systemd unit, common secure installer, RHEL and Ubuntu entrypoints, shared Linux preflight, release verifier, optional source-bank preparation helper, installation text and operating guides are included. The archive does not contain an enrollment token, private endpoint key or controller secret.

Endpoint family	Required OS packages	Entry script
RHEL 8 or 9	systemd, iproute, firewalld, ca-certificates	install-agent-rhel.sh
Ubuntu 26.04	systemd, iproute2, firewalld, ca-certificates	install-agent-ubuntu.sh

Packages carry detached Ed25519 signatures. Obtain the verifier and release public pin independently; an adjacent downloaded public key is not a trust decision. The current authority is the local project key, not organizational approval. Verify exact bytes before extraction; preserve root-owned release files.

The family scripts check versions, architecture and dependencies. They do not run apt/dnf, disable UFW, enable firewalld or migrate rules. Package installation itself may activate a service through OS hooks, so schedule that separate preparation explicitly.

Source references [12] [14] [15]

ENDPOINT SETUP

Install and configure the endpoint

Verify the matching agent archive using the page 9 verifier pattern on an approved administration machine, then transfer the verified bytes securely. This extraction example uses amd64; substitute arm64 for ARM64 hosts. Set the stable HTTPS origin and trusted credential paths in the private config.

```
sudo install -d -o root -g root -m 0755 /opt/prthak/agent-releases
sudo tar --no-same-owner --no-same-permissions \
  -xzf /protected/releases/prthak-agent-0.6.0-linux-amd64.tar.gz \
  -C /opt/prthak/agent-releases
cd /opt/prthak/agent-releases/prthak-agent-0.6.0-linux-amd64
```

```
sudo install -o root -g root -m 0600 \
  agent/config.example.json /root/prthak-agent.json
sudoedit /root/prthak-agent.json
sudo install -d -m 0700 /etc/seg-agent
sudo install -o root -g root -m 0600 /path/to/enrollment-token \
  /etc/seg-agent/enrollment-token
```

Run the matching family entrypoint

```
./scripts/install-agent-rhel.sh --check-only
sudo ./scripts/install-agent-rhel.sh \
  --ca-file /path/to/trusted-controller-ca.pem \
  --token-file /etc/seg-agent/enrollment-token \
  /root/prthak-agent.json
```

Ubuntu uses install-agent-ubuntu.sh with the same arguments. The common installer validates config/CA/private token and pending-transaction safety before replacement. It enables and starts seg-agent, then distinguishes a confirmed first report from pending automatic retries.

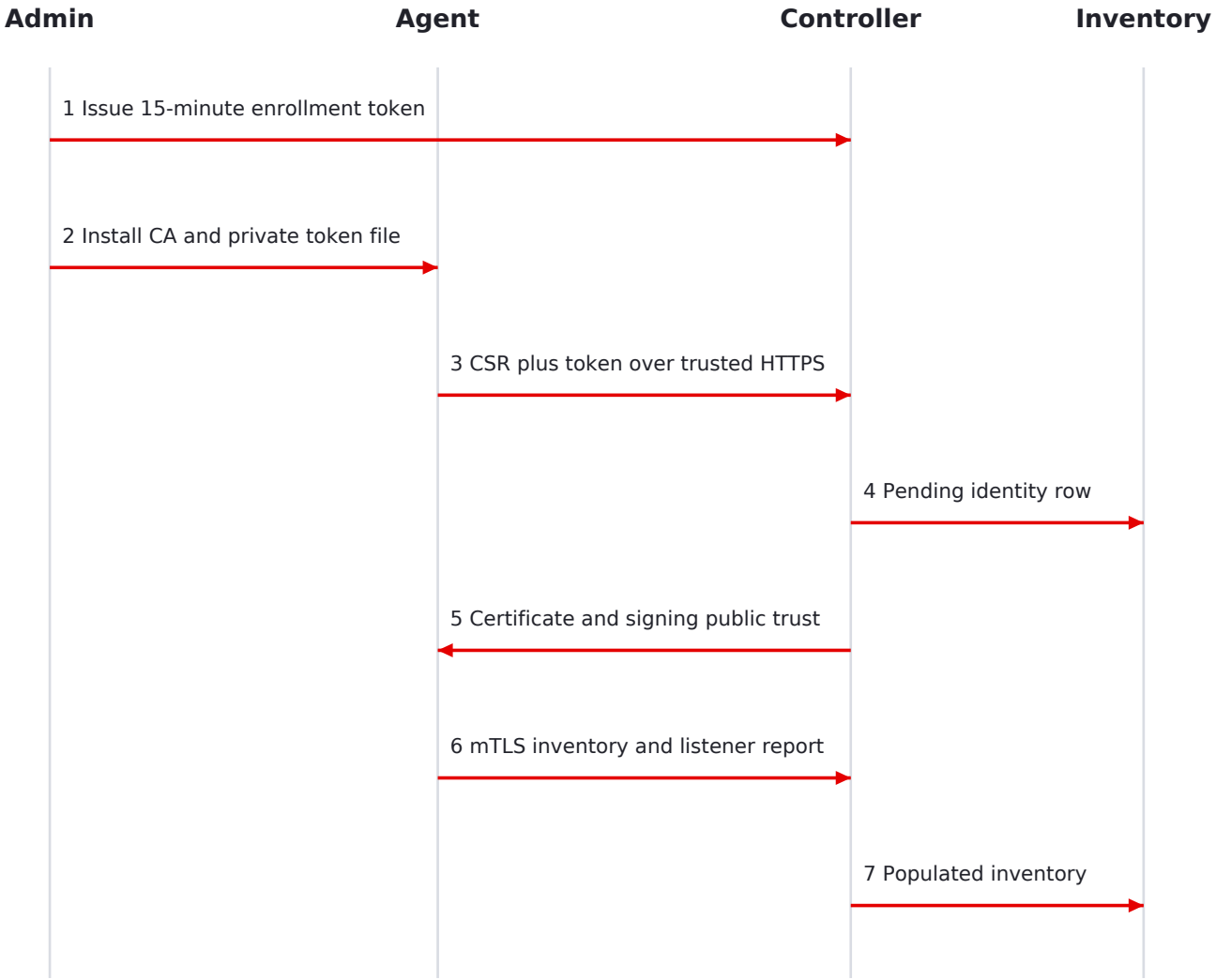
Config field	Meaning
controller_url	Trusted HTTPS origin and port, without /api/v1, credentials, query or fragment.
ca_cert / endpoint_ca_cert	Web server trust; separately preinstalled endpoint issuer trust when different.
interval_seconds / discovery_interval_seconds	Local fallback 60/900. Central versioned polling profiles can override them.
enforce and learning_auto_allow	Keep false until the respective reviewed protection/approval prerequisites.
state_dir and identity	Keep canonical private state; never clone agent identity across servers.

The --ca-file option copies web trust only. A different endpoint issuer must already be installed and configured before preflight. No inbound agent daemon port is opened.

Source references [12] [15] [16]

ONBOARDING SEQUENCE

What happens after installation



The enrollment token is identity-only, single-use and expires after 15 minutes. The agent persists its key/CSR; the same CSR and hostname can recover an interrupted issued response within the permitted retry window. A changed request cannot reuse it.

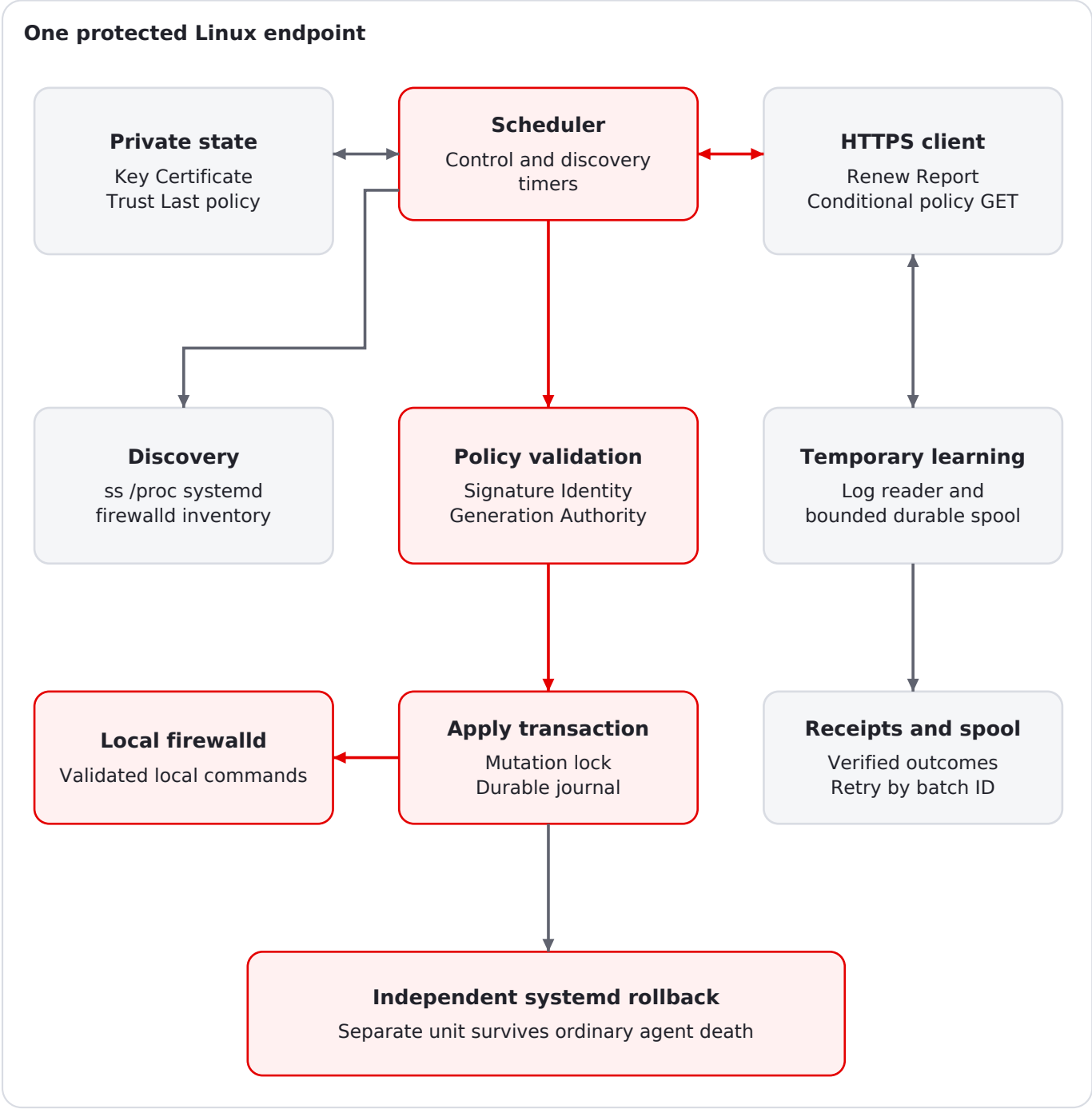
Enrollment may create a warning/pending placeholder with empty addresses/listeners. The first authenticated report supplies live hostname, IPs, services and readiness. Installation success alone is not proof of populated dashboard inventory. Business tags/DC are assigned centrally, not accepted from the agent or token.

After a controller outage the service retries with bounded backoff. Preserve private state during upgrade/restart; use a separately issued recovery credential when identity recovery is required. Endpoint leaves last 90 days, renew within the 30-day window and use a tracked 24-hour overlap.

Source references [3] [9] [15]

ENDPOINT RUNTIME

Inside the lightweight systemd agent



Normal cycle: renew if needed, report inventory/outcomes, conditionally pull policy, validate signature/identity/replay floor, process authorized work and send another receipt only when meaningful state changed. Local cached policy remains when the controller is unavailable.

Root privileges support process/journal discovery and firewalld authorization. The stock unit restricts filesystem writes to protected state and uses systemd hardening. It is not an arbitrary remote command runner.

Source references [9] [15] [16]

INVENTORY AND MONITORING

Service discovery and health alerts

Discovery runs at startup and every 900 seconds by default. It reads TCP/UDP listeners with ss -H -lntup, interface addresses and process/systemd identity. SSH on 2022 is identified from the executable/unit, not inferred from a conventional port number.

Change or signal	Dashboard behavior	Meaning and limit
New listener after installation	Server service list and discovery alert/highlight after the next successful scan.	A running listener is not proof of end-to-end application success.
Listener disappears	Compare expected/previous service state; generate down/recovery events.	Port presence is separate from an application transaction probe.
Heartbeat stops	Health evaluator detects stale endpoint; no fresh rule-state assumption.	A controller outage does not erase committed endpoint firewall rules.
Discovery fails	Retain last successful listeners/timestamp and show scan error/staleness.	A cached heartbeat must not claim a fresh scan.
firewalld reported unavailable	Critical availability occurrence; kernel rule state is unverified.	Recovery needs a later nonstale running report; no inferred recovery while offline.
Policy intent differs from receipt	Desired/applied versions and error/drift signals remain distinct.	Downloaded or preview status is not enforced status.
Closed-port probing	Optional unexpected-port monitor; possible scan alert at five ports/five minutes.	Opt-in sampled observation; not complete lateral-movement correlation.

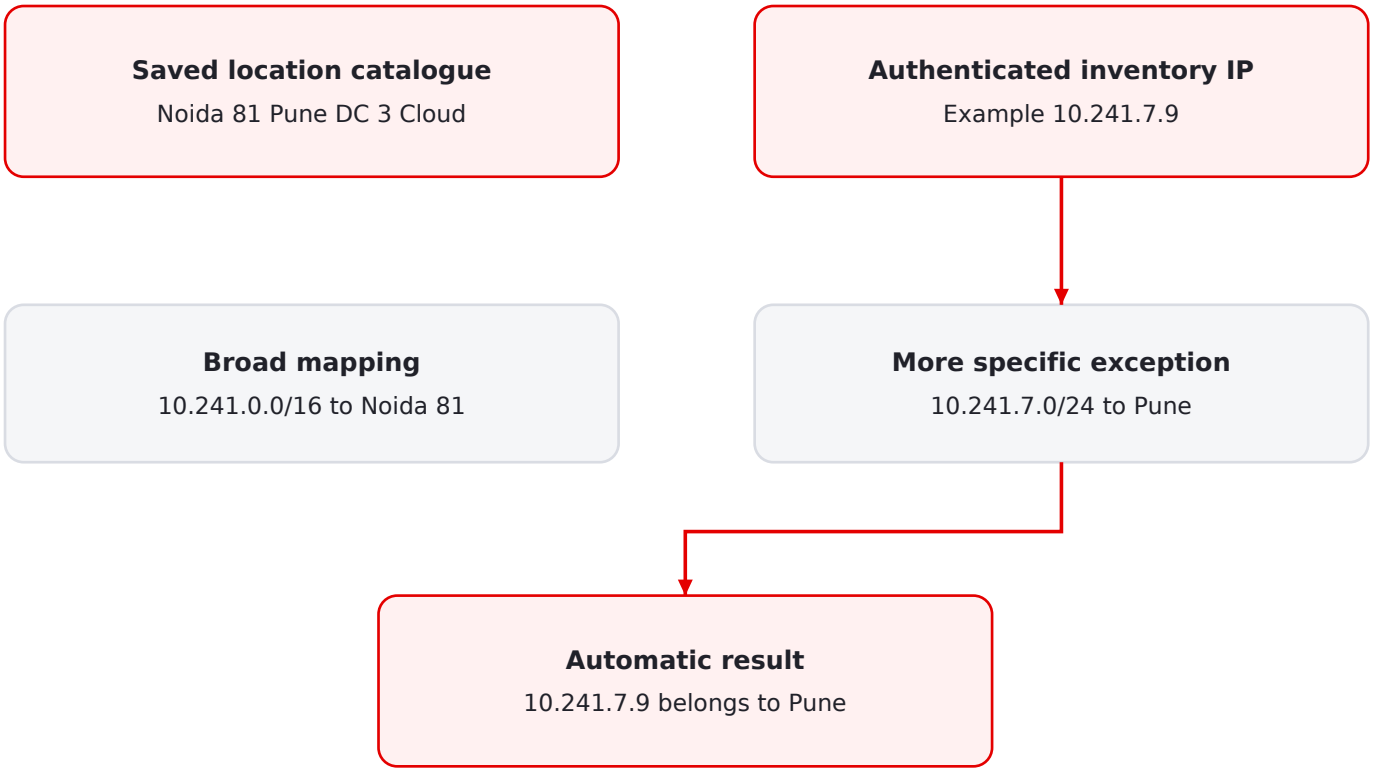
The health evaluator runs on a timer and can notice missing data. Listener discovery and reported firewalld state follow configured agent cadence. Log collection is separate and does not run permanently just because inventory discovery is enabled.

Source references [1] [15] [17]

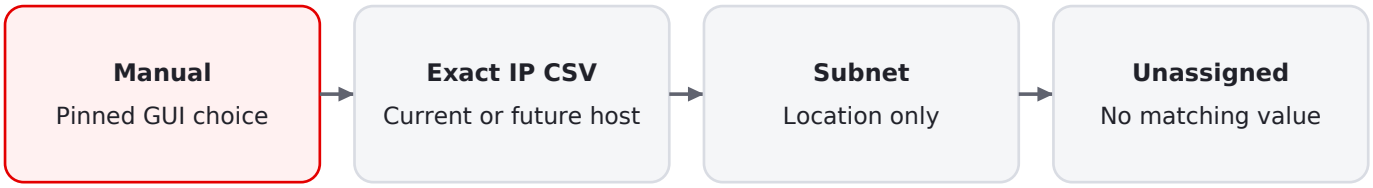
CENTRAL METADATA

DC assignment tags and grouping

Create saved Locations/DCs manually first. A server has one saved location and several business tags. Application process identity from discovery does not create an application ownership tag. Use individual editing, reviewed bulk assignment, exact-IP CSV profiles or subnet mappings.



Per-field precedence



A /24 exception inside another DC's /16 is allowed. The exact normalized CIDR cannot belong to two locations. Conflicting addresses on one host, ambiguous exact-IP profiles and duplicate IP ownership across locations are held as conflicts rather than assigned silently.

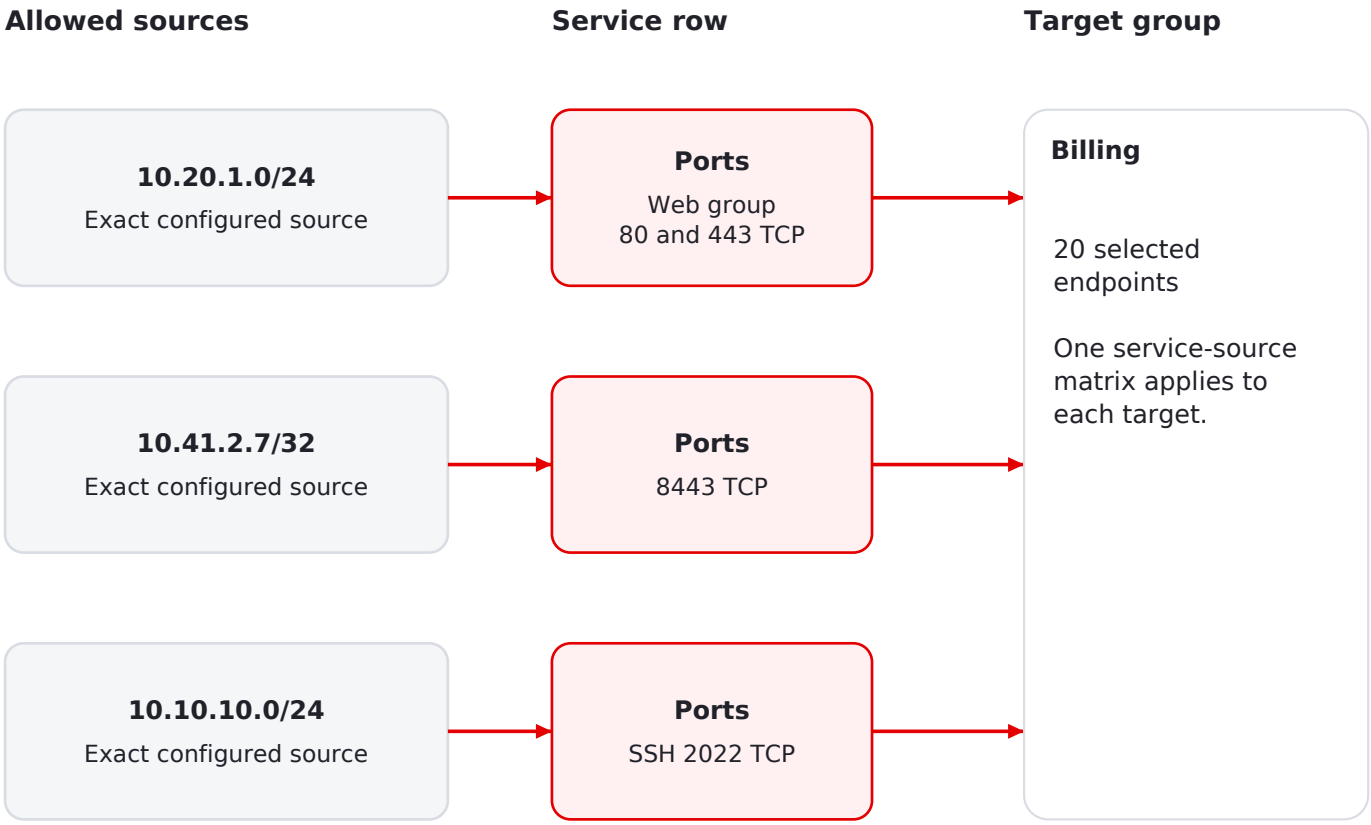
Manual removals and explicit Unassigned remain pinned until reset to automatic. Subnets supply location only. Regions shown in synthetic examples are not automatically created production DCs.

Source references [1] [18]

POLICY MODEL

One policy for a group of servers

The target server/group/tag selection supplies the destination implicitly. A service row maps its allowed sources to exact TCP/UDP ports. Reusable service groups can contain several ports; source CIDRs, source selectors and source groups can be combined within a row.



Destination is implicit

The selected endpoint is the destination. Keep source sets aligned with each service row; a row using a service group intentionally applies its sources to every port in that group.

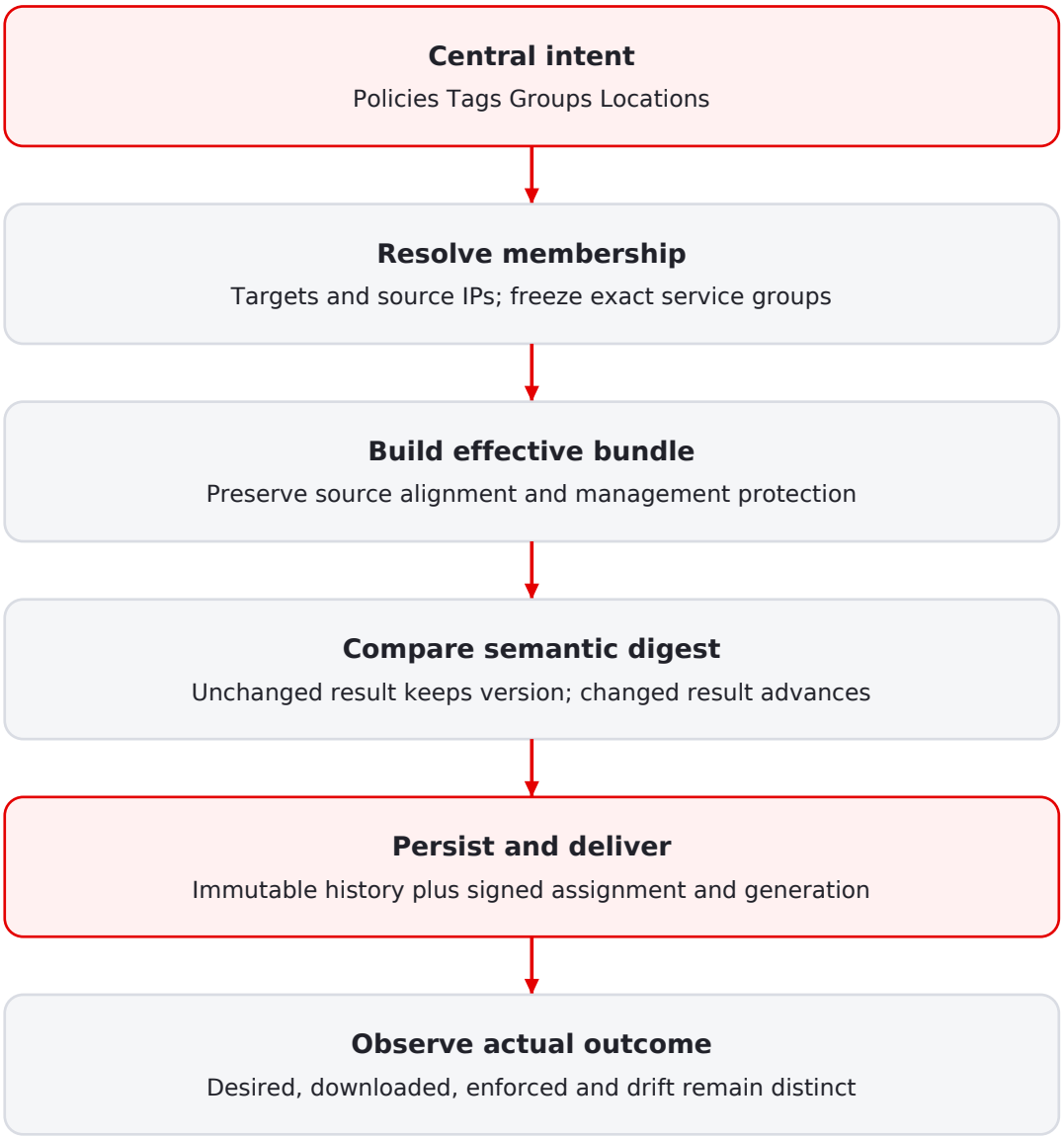
For Billing with 20 servers, one target policy can cover all members. A tag or source-group membership change recompiles affected endpoints. Source groups use authenticated reported IPs, never an unverified planned reservation. Monitor rows cannot widen an enforced port.

The supported adapter restricts selected managed inbound ports while preserving unrelated configuration. It does not automatically close every other port, enforce egress/container forwarding or terminate existing conntrack sessions.

Source references [1] [19]

POLICY DELIVERY

Compilation versions and drift



The signed complete assignment covers policy plus auxiliary learning, imported-action and polling intent. Its durable assignment generation/digest and the endpoint's replay floor are separate from the semantic policy version. A stopped learning assignment must not become active again through replay.

Per-endpoint version/digest receipts expose progress and errors. A 304 avoids transferring unchanged content only after current authentication/authority evaluation. No version-only authority cache was added for performance. Review the live firewalld snapshot before treating stored intent as current kernel state.

Source references [3] [19] [20]

SAFE ENFORCEMENT

Managed policy approval and apply

Saving intent does not authorize kernel mutation. Real enforcement requires local opt-in, complete management protection and an exact independently reviewed rollout. Both requester and checker must remain enabled with current appropriate Entra roles.

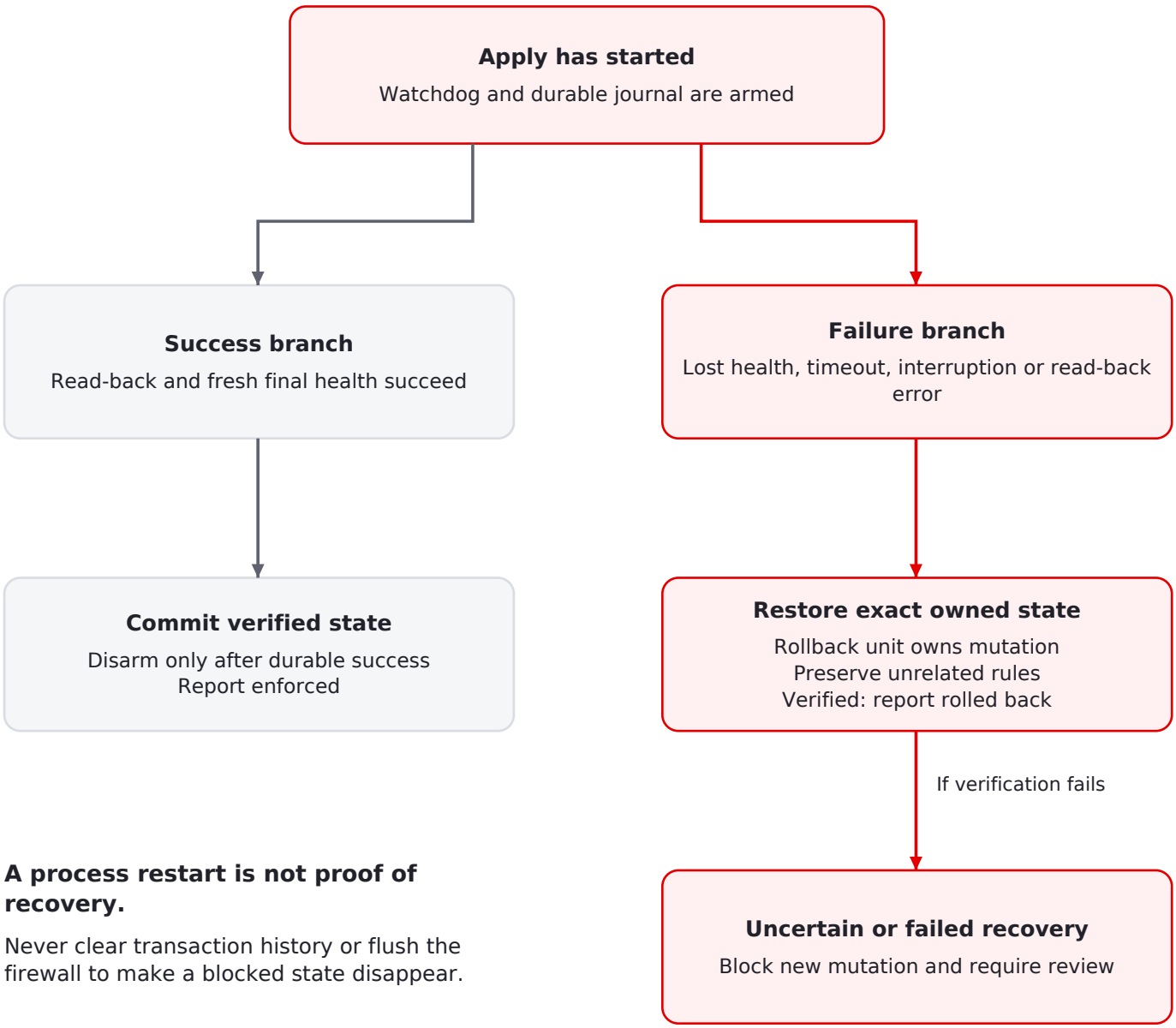


SSH/controller lockout protection uses pinned management source networks and actual protected SSH ports. The controller performs a fresh SSH-banner probe; it does not log in over SSH. Unsupported zones, conflicting managers or missing prepared source banks block before mutation.

Source references [8] [20] [21]

FAILURE PROTECTION

Automatic rollback and uncertain states



A process restart is not proof of recovery.

Never clear transaction history or flush the firewall to make a blocked state disappear.

The rollback unit is separate from the ordinary agent service. A shared mutation lease and durable ownership prevent rollback racing owned helper commands; uncertain imported-rule recovery remains blocking until the exact baseline is verified.

After a mutating failure, approval/grant state is held for review. Restarting the agent, receiving another hit or changing an unrelated generation does not authorize an automatic retry. Immutable version history can restore prior intent as a new reviewed version.

Stopping firewalld itself is different from a controller outage: daemon cleanup behavior can remove rules. Check service and actual rule state; never infer continued protection from a saved dashboard policy alone.

Source references [20] [21]

OBSERVATION WORKFLOW

Temporary traffic learning

Choose a bounded session on selected endpoints and ports. For a server listening on 22, 80 and 443, select 443/TCP only. Automatic discovery still reports its inventory, while the learning session freezes only that endpoint's eligible selected ports.



Observation adds runtime log-only rules with expiry, not access rules. The collector reads the owned kernel-journal prefixes, persists bounded batches and uploads exact source/port/protocol/time evidence. Logs are rate limited to 20 events per second per rule and can be incomplete.

The last-hour chart is a query window, not a guarantee that the preceding hour was fully observed. Counts represent observed log events/attempts, not guaranteed complete connections, application requests or trusted clients.

Source references [15] [22]

LEARNING OWNED ACCESS

Suggested policy and automatic learning

Mode	What it does	Required review and lasting state
Observe	Collect exact source-port pairs; show recommendations and export CSV.	No access grant. Admin reviews and applies selected evidence to a frozen target scope.
Auto-allow	Eligible observed exact source/port tuples generate separate learned allow policies.	Explicit local switches plus independent initial Entra approval of frozen hosts, ports and expiry.
Manual learned edit/removal	Change or remove an existing learned overlay through its own workflow.	Exact reviewed nonce/digest and current target/protection bindings; removal waits for endpoint receipt.

Example service on TCP 8443

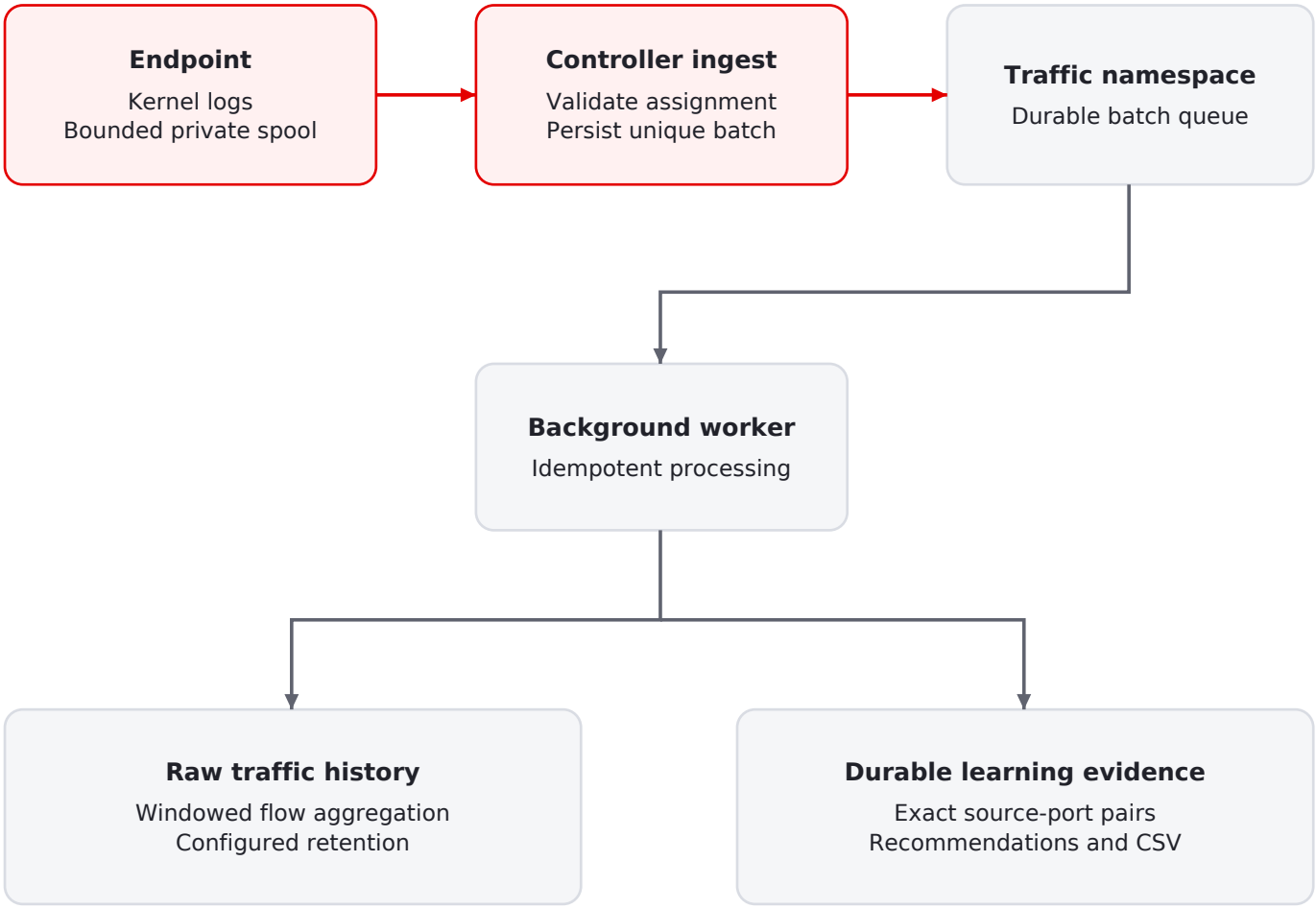
- Enable learning for 8443 only. Do not instrument SSH or other services simply because they are running.
- Freeze each selected host's fresh listener scope; a later newly started port needs another learning session.
- After independent initial auto-allow approval, an eligible local observation can add 10.20.1.25/32 only to 8443/TCP on that endpoint.
- The generated learned policy becomes visible separately on the dashboard, with its own generation and endpoint outcome.
- Stop/expiry removes temporary logging and stops new automatic additions. Already committed accepts remain until a reviewed removal is confirmed.

Auto-allow can admit scanners or unwanted clients; observed sources do not prove legitimate business intent. Protected management/controller ports and invalid sources are excluded. An additive allow overlay alone cannot reject other sources while an existing broad opening remains. Use separately approved managed enforcement for exclusive source restriction.

Source references [8] [22] [23]

DATA LIFECYCLE

Traffic data evidence and NAT



202 means the validated batch was durably queued.

It does not mean that an access policy or kernel rule was applied. Cross-store receipts make processing replay-safe.

Raw traffic retention defaults to 24 hours and is configurable. Durable learning evidence supports exact recommendations/CSV independently of the small chart page. Export completeness and coverage must be assessed with collection gaps and limits visible.

Control-path NAT does not replace server.ips: inventory uses only the authenticated agent payload, not the TCP peer or forwarded header. Application-path NAT is different: the destination kernel may see the NAT gateway as source. The agent cannot automatically recover the original client IP.

Source references [3] [22] [23]

DAY TWO OPERATIONS

Platform operations from the GUI

Super Admin uses reviewed Platform workflows for privileged changes. The unprivileged controller queues fixed jobs to the local manager; it has no Docker socket or arbitrary remote shell authority. Queued, completed and verified healthy are distinct states.

Workflow	Operator action	Verification and boundary
Join another node	Install same release, enter existing peer IP and shared cluster password; compare HTTPS fingerprint and confirm trust.	Password is not sent before trust approval. Once three eligible distinct-site voters exist, additional management nodes do not add voters.
Services	Review exact service start/stop/restart and type the confirmation.	Manager rechecks ownership/dependencies/quorum; inspect actual health.
TLS certificates	Import PEM or PKCS#12, or generate a reviewed hostname/SAN certificate.	Validate key/chain/name/usage; retain rollback identity. Web, endpoint and internal CAs remain separate.
Public application port	Review candidate port and external dependencies; supervised apply verifies listener and rollback.	External LB, DNS, Entra redirect registration and agent origins are not automatically rewritten.
Agent polling	Review global defaults and group/tag/server overrides; verify applied version/digest.	Use 30/900 for the measured capacity profile; this cannot enable firewall writes.
Storage directory	Prepare a real mounted filesystem, then review GUI data-root move.	Writers stop, copy/check/fsync and boot pointer change; original remains. GUI does not mount or format disks.
Notifications	Review Slack/webhook/SMTP recipients and trust before enabling.	Secrets sealed; retries/ambiguous acknowledgement tracked. Actual provider acceptance remains separate.
Upgrade / retirement	Verify release; preserve identity/state; use transaction-safe replacement or reviewed retirement.	Pending rollback blocks upgrade. Retirement is not silent uninstall or deletion of firewall rules.

Controller-local DATA_ROOT holds config, PKI/Vault, databases, etcd, journals and local backups. Keep matching protected material and off-node copies. Do not manually copy live PGDATA or delete pending transaction journals.

Source references [4] [6] [24]

BACKUP AND DR

Backup schedules and reviewed recovery

Backups create paired SQLite snapshots or PostgreSQL custom dumps. Schedule daily, weekly or every 1 to 168 hours with an IANA timezone and retention of 1 to 365 archives. Schedules start disabled; one most-recent missed slot can catch up. Bytes and retention are controller-local even when schedule coordination is shared.



Database archives exclude private PKI, Vault/profile/key/environment secrets and the backup directory. Protect the matching private recovery context separately. Structural validation or downloading an archive does not restore a live deployment.

GUI recovery requires a healthy current safety ledger, matching private material and all required peers. Missing current context or peer acknowledgements can block release. It is not a complete archive-only offline DR or PITR/WAL-based RPO procedure. Preserve originals; complete compromised-CA recovery is a separately fenced operation.

Source references [6] [25]

OPERATING PLAYBOOK

Failure states and first checks

What you see	What happens	First checks
Agent not visible/populated	Enrollment may be pending; successful file install is not readiness.	Private config/CA/token validity; systemctl status; journal; --status; stable controller origin.
Agent heartbeat stale	Rules already committed stay; fresh state cannot be inferred.	Network/TLS/clock/identity and endpoint service; do not use allow-all reset.
No new listener after startup	Discovery is periodic and cached heartbeats do not rescan.	Last discovery time/error; configured 900 s interval or --scan-now.
No sources in last hour	Collector may be off, wrong port, expired or interrupted.	Session exact scope, endpoint collection state, coverage/rate-limit gaps and batch processing.
Policy downloaded but not enforced	Preview, missing approval/protection, or unsupported context may block.	Exact desired/applied digest, local flags, current independent review, zones and management witness.
Rollback uncertain or error	Further mutation stays held.	Retain journals; inspect exact baseline/read-back and independent rollback service before review.
Controller unavailable	LB can use a configured ready peer; endpoint committed rules remain.	/readyz on actual TLS route; DB namespaces/epoch; no local SQLite fallback in HA.
Database primary unavailable	Patroni/etcd/fencing govern promotion; strict sync can block writes.	Quorum, eligible standby, watchdog and real commit path. Liveness alone is insufficient.
IP or DC conflict	Automatic location/source mapping may be withheld.	Agent-reported IPs, exact-IP CSV bindings, most-specific subnet and manual overrides.
Restore cannot release	Current safety context or registered peer ACK may be missing.	Review immutable stage, current private material/fences; do not expose retained originals as a second writer.

Treat status labels as evidence at a particular time. A listening port, a successful HTTP health probe, a completed manager command and a successful business transaction answer different questions.

Source references [4] [17] [20] [25]

CAPACITY AND PERFORMANCE

Validated 5000 server delivery profile

The local frozen-source workload used 5,000 distinct registered mTLS identities, real Gunicorn TLS and a PostgreSQL metadata/traffic pair. It edited a real monitor policy through the API and verified every new version, digest, exact source matrix and receipt.

Measured phase	All identities complete	Elapsed
Initial signed policy and receipts	5,000	14.255 s
Real policy edit plus publication and 30 s polling spread	5,000	30.684 s
Warm polling plus discovery and traffic	5,000	9.791 s

Profile	Value
HTTP workers / threads	2 / 32 per worker
Metadata / traffic connection pools	8 / 2 per worker; wait up to 5 s
Actual central control / discovery	30 / 900 seconds
Workload	Two monitor services, 20 sources each, 64 virtual clients
Mixed phase	100 fresh discoveries and 100 learners with 100 events each
Outcome	Zero failures/retries; 10,000 retained flow events; no pending batch

Publication/compilation consumed 0.676 seconds inside the edit phase. Existing raw agent/control defaults remain 60/900; configure and confirm 30/900 centrally, including applicable overrides, for this freshness profile.

The host was shared macOS ARM64 with 10 logical CPUs and one local PostgreSQL 16.15 instance. These are virtual identities, not 5,000 Linux processes. Enrollment storms, largest policies, 5,000 active collectors, long soaks, WAN/quorum and native firewalld timing remain separate acceptance. Additional controller VMs do not remove shared-writer/replication latency.

Source references [2] [13]

RELEASE READINESS

Pilot acceptance and current boundaries

Code and isolated validation are concrete, but the intended 20-server DC pilot has not started. Native RHEL 8/9 and Ubuntu 26.04 testing and DC deployment are deferred to the operator. Use controlled cohorts and retain out-of-band management.

Acceptance area	Required evidence before expansion
Identity and access	Real Entra tenant/MFA; all three roles; disabled/revoked users; exact agent renewal/revocation/recovery; trusted web/endpoint/signing pins.
Native endpoint safety	Actual kernel/systemd/firewalld/SELinux/polkit; SSH custom ports; IPv4/IPv6; forced termination, reboot/reload and failed rollback.
Network and HA	Actual LB/SNAT and certificate passthrough, synchronous commit latency, native watchdog reset, site partitions and measured RPO/RTO.
Workload and resources	Real policy/source sizes, periodic discovery, traffic learning bursts, long-running CPU/RAM/disk, outages and resource headroom.
Operations and recovery	Off-node protected backup/private-context copies, actual provider delivery, owned restore drill, supervision and participant ACKs.

Scope that must not be assumed

- The current adapter covers selected inbound host TCP/UDP services. Whole-host default deny, egress and container/forwarded paths need additional design.
- Canary/cohort automation, change windows, semantic rule-shadow analysis, broad multi-host lateral correlation and signed RPM/DEB repositories are not supplied by this release.
- Package/etcd vendor vulnerability findings remain open. Scoped code fixes, passing tests and a capacity result are not production security clearance.
- Do not enable endpoint enforcement or automatic learning on controller, database and LB infrastructure during this pilot without native topology-specific ingress protection.

Current checkpoint: 678 controller tests and 230 dashboard tests pass; integration completed 221 passes and one Mac/Linux-kernel skip with separate Linux evidence. These totals do not replace the acceptance areas above.

Source references [1] [2] [26]

QUICK REFERENCE

Files commands and service reference

Item	Location or command
Agent service / executable	seg-agent.service /usr/local/bin/seg-agent
Agent config / bootstrap token	/etc/seg-agent/config.json /etc/seg-agent/enrollment-token
Private identity and cached state	/var/lib/seg-agent/agent.crt and agent.key State, trust, spool and transaction history under state_dir
Controller persistent state	DATA_ROOT default /var/lib/prthak
Committed data-root pointer	/etc/prthak/data-root
Fixed appliance manager	prthak-appliance-manager.service /run/prthak-appliance/manager.sock
Initial admin token / setup CA	DATA_ROOT/config/controller/initial-admin-token DATA_ROOT/config/controller/pki/ca.pem

Endpoint checks

```
sudo systemctl status seg-agent.service
sudo journalctl -u seg-agent.service -f
sudo /usr/local/bin/seg-agent \
  --config /etc/seg-agent/config.json --status
sudo /usr/local/bin/seg-agent \
  --config /etc/seg-agent/config.json --scan-now
```

--scan-now requests the running agent to rescan; it does not create another identity. A stopped/manual --once invocation performs a fresh scan and policy sync but is not a replacement for the systemd service and its learning cleanup.

Three different health checks

/healthz reports process liveness. /readyz checks required dependencies/identity for routing. Fresh enforcement witnesses separately prove controller mTLS and configured SSH-banner reachability. None is a complete business-application test.

Source references [11] [12] [15] [16]

REFERENCE REGISTER

Source references and edition record

[1] docs/architecture.md
Product scope, data paths and known boundaries

[2] docs/controller-capacity-5000.md
Current measured 5,000-identity result and configuration

[3] controller/app.py and controller/store.py
API dispatch, inventory, policies, alerts and outcomes

[4] deploy/appliance/node_manager.py
Actual ports, fixed manager, routing and platform services

[5] controller/production_http.py + controller/pg_pool.py
Bounded serving and post-fork connection reuse

[6] docs/ha.md and controller/cluster_bootstrap.py
Join, multi-controller/shared-writer and voter topology

[7] controller/management_health.py
Controller-to-endpoint SSH-banner witness

[8] docs/authentication.md and controller/approvals.py
Human roles, Entra and independent approval

[9] controller/endpoint_certificates.py
Registered endpoint identity and certificate lifecycle

[10] controller/internal_certificates.py
Internal service trust and lifecycle

[11] docs/controller-installation.md + docs/controller-vm-requirements.md
Controller installation and starting VM allocations

[12] docs/linux-agent-installation.md and scripts/install-agent*.sh
Distro entrypoints, dependency preflight and secure installation

[13] output/capacity/validation-summary.json
Exact tests, capacity, image and artifact provenance

REFERENCE REGISTER

Source references and package record

[14] docs/agent-resources.md and .local/capacity/release-verification.json
Measured resource scope and exact current package sizes

[15] agent/README.md and agent/internal/agent/runner.go
Agent lifecycle, discovery, scheduling and opt-ins

[16] deploy/systemd/seg-agent.service
Root service and filesystem hardening

[17] controller/store.py health and discovery functions
Expected state, stale reports, service and firewall alerts

[18] controller/metadata.py and docs/architecture.md
Manual/CSV/subnet precedence and conflict handling

[19] controller/service_groups.py
Per-row port/source alignment and resolution

[20] docs/managed-enforcement.md
Management protection, journals and immutable history

[21] agent/internal/agent/managed.go + agent/internal/agent/managed_health.go
Runtime staging, health, commit and rollback

[22] controller/learning.py + controller/learning_policies.py
Frozen discovery, evidence, suggestion and learning authority

[23] agent/internal/agent/collector.go + agent/internal/agent/learning_allow.go
Sampled logs and separate persistent additive grants

[24] controller/appliance.py + controller/notifications.py
Privileged GUI jobs and optional delivery channels

[25] controller/maintenance.py + controller/backup_schedule.py + controller/recovery.py
Backup, schedules, recovery and safety ledger

[26] docs/security-assessment-2026-10-31.md
Prior audit scope and open vendor/native acceptance gates

Source paths are relative to the standalone Prṛthak repository. Private evidence paths are references only; no keys, tokens, passwords, certificates with private material, databases or customer host records are embedded. Diagrams are explanatory original vector graphics, not live topology or deployment evidence.

Current package SHA256 digests

`prthak-controller-0.6.0.tar.gz`
`42c01f8a49a6898a8b458e55f7746ce6a7d83ad2c0c1db2b2c85f574709c8226`

`prthak-agent-0.6.0-linux-amd64.tar.gz`
`4120f385991fc8b1f947cecdd6dff1dc92cfc4a22cf3ad356618dce274dd2b65`

`prthak-agent-0.6.0-linux-arm64.tar.gz`
`666aecf8c1c9d6e8979498ec7be44063e34afce6e00c9b9cc6d1675d667e86a5`